

Final Lesson

Introduction to Adversary Simulation (Red Team)

Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

Lesson sequence

Lecture

Exam Requirements

Week 13 Presentation Briefing

What is Red Team?



You

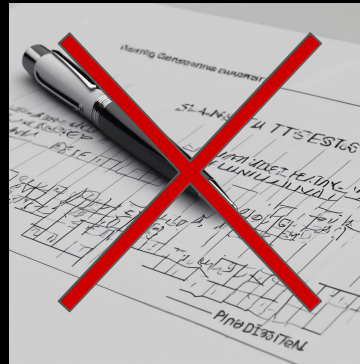
In no less than 20 words, explain the concept of Red Team



ChatGPT

A Red Team simulates adversary tactics to rigorously test and identify weaknesses in an organization's security systems, improving overall defense capabilities.

We are paid to create trouble.



Should Be vs What is

SHOULD BE

The S3
buckets
should only
be
accessible
by lambda
functions

Discovery



WHAT IS

The S3
buckets
was
accessible
by public
internet

What can
we achieve
afterwards?

PPO

People

- Users, Clients, Supporting functions, Engineers

Process

- Change management, IT Operations, Asset Management

Organization

Organizational Structure, [Budget Priorities](#)

Red Team Testing

We cover end to end scenarios.

We emulate threat actors and scenarios based on an organization's threat profile

Study past breaches

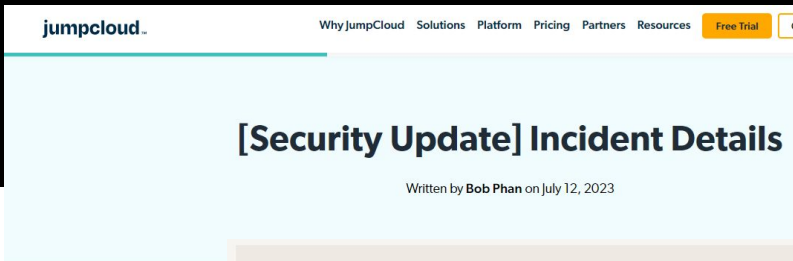
February 8, 2024

Okta October 2023 Security Incident Investigation Closure



David Bradbury

Related Posts: [Recommended Actions](#) - Nov 29, 2023 / [Root Cause Analysis \[RCA\]](#) - Nov 3, 2023 / [Security Incident](#) - Oct 20, 2023



[Blog Home](#) > [News](#) > [\[Security Update\] In](#)

Blog / Product news

A recent security incident involving Dropbox Sign



by Dropbox Sign team
May 1, 2024 • 6 minute read

Just Some Time Ago

THE STRAITS TIMES

SINGAPORE

LOG IN SUBSCRIBE

Sign up for a FREE
Phillip MetaTrader 5 demo and access
global markets at your fingertips!

Phillip
MetaTrader 5

Jumbo Group, Mustafa hit by cyber attacks



Seafood restaurant chain Jumbo said it was targeted in a ransomware incident, while the Mustafa group – which runs a mall in Little India – was hit by a data leak. PHOTOS: JUMBO GROUP OF RESTAURANTS, MARK CHEONG

Goals?

The answer to your goals in a red team engagement depends on your operating scenario.

Which threat actor
are we emulating?

Is it a feasible
attack vector?

Regulatory
concerns?

What are out of
scope?

Crown Jewels?

Goals?

Achieving the goals is the single most “important” task. Everything is secondary.

Which threat actor
are we emulating?

Is it a feasible
attack vector?

Regulatory
concerns?

Do whatever it takes

What are out of
scope?

Crown Jewels?

Current Works

Let's explore what others have said about Red Team Engagements.

Current Works

“Engagement planning is **crucial** to manage potential engagement risk effectively, successfully execute desired goals and objective, and providing the information required to improve both organizational and defensive capabilities. Likewise, effective planning dramatically increases the speed and accuracy of both engagement culmination and reporting.” – (2020, RED TEAM DEVELOPMENT AND OPERATIONS, Joe Vest & James tubberville)



Current Works

“Stealth operations are not a contest. If our Red Team completes an objective undetected, we can offer **recommendations to improve our detections**. If we trigger a response, we’ve validated that detection capability in a realistic scenario and allowed the team to work through the **same processes they would use when responding to real-life attacks.**” - The GitLab Handbook: Red Team

Current Works

Red Team Maturity:

Level Descriptors

Level 1 - Occasional, Not Consistent, Not Planned, Disorganized, One-Size-Fits-All, Basic Technical Capability, No OPSEC Considerations

Level 2 - Intuitive, Not Documented, Occurs Only When Necessary, Inconsistent Manual Processes, Somewhat Effective Capability, Limited OPSEC Considerations

Level 3 - Documented, Predictable, Evaluated Occasionally, Understood, Custom Technical Solutions, Documented Manual Processes, Primary-Use Effectiveness, Best-Practice OPSEC Considerations

Level 4 - Well-Managed, Formal, Often Automated, Evaluated Frequently, Majority-Effective Capability

Level 5 - Continuous and Effective, Integrated, Proactive, Usually Automated, Easily Customized, Fully Effective Capability, Advanced OPSEC Considerations

<https://www.redteammaturity.com/>

Current Works

Operational Planning and Selection

Level 1

Operation objectives are selected by individual interest or urgent need; planning may not include input from the whole team; operations are planned within a few weeks of commencement

Level 2

Operations target major services, infrastructure, or offerings of the organization

Level 3

Operations leverage Cyber Threat Intelligence to derive objectives and are planned out at least one quarter; the Red Team has a defined intake process for suggestions and operational needs

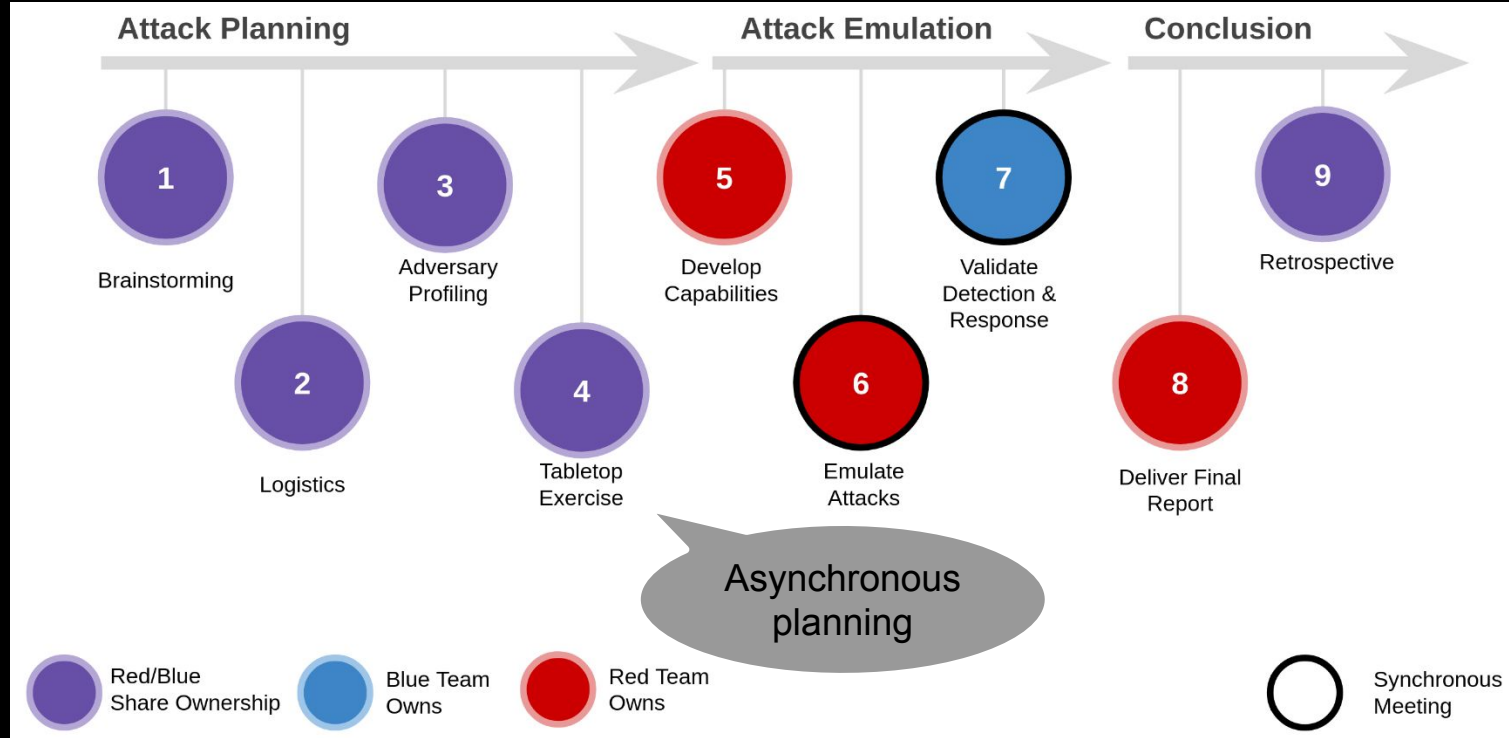
Level 4

Operations draw from Cyber Threat Intelligence, responders, hunters, and engineering/architecture teams' concerns; operations are planned for 2+ quarters

Level 5

Operations are based on objective criteria that consider business needs, threat intelligence, criticality, and/or other organizationally defined measures; unscheduled operations can be added ad hoc to address urgent issues without impacting other deliverables

Current Works



But how can we do “that” process of planning?



Majority talks about **what**
you need to do, have you
ever wondered **how**
should we do it?

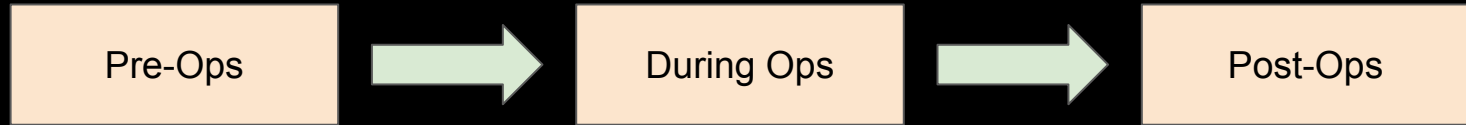
My Vision of Red Team Planning

DISCLAIMER:

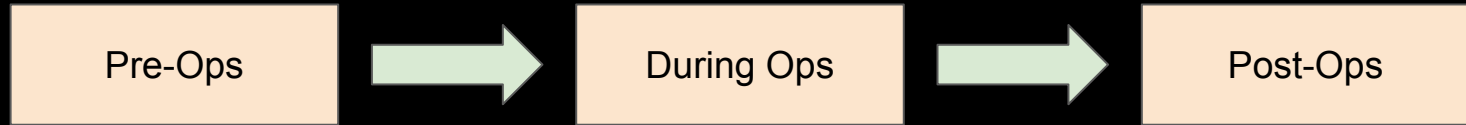
The following views are solely mine, and how I think an internal Red Team should organize and plan an engagement. They are not the views of my employer, nor organization I am affiliated to.

However, this might be useful for external Red Teams, but please listen with an open heart and mind. <3

My Vision of Red Team Planning

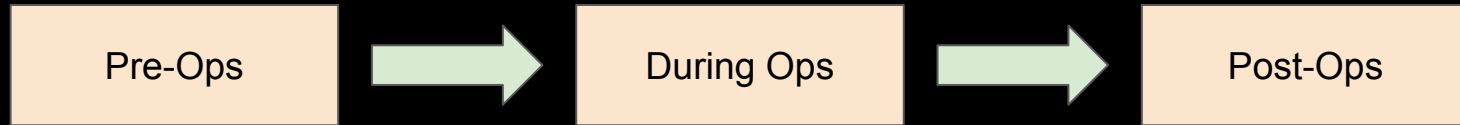


My Vision of Red Team Planning



For this talk, we will go in detail on Pre-Ops elements.

My Vision of Red Team Planning



2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

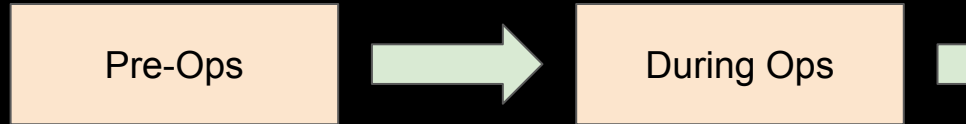
Logistic and Force preparation

Ops planning

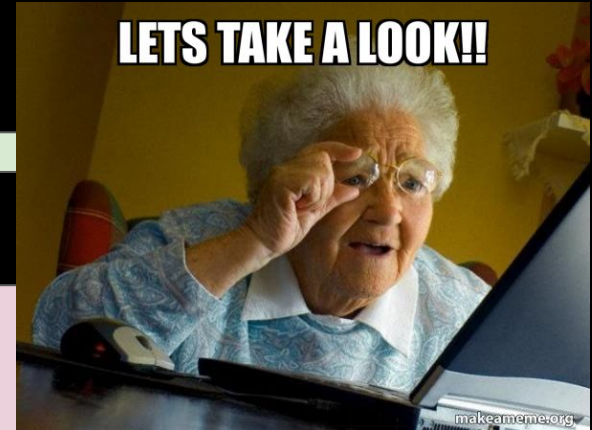
Contingency planning

Dry runs and rehearsals

Let's take a closer look at Pre-Ops

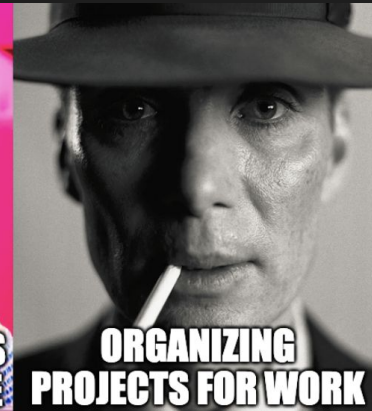


2 ~ 6 months before Ops
Scoping of engagement
Stakeholder onboarding
Pre-Ops meeting
Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals



Let's take a closer look at

Pre-Ops



2 ~ 6 months before Ops

Scoping of engagement

- Stakeholder onboarding
- Pre-Ops meeting
- Sub-Task study
- Logistic and Force preparation
- Ops planning
- Contingency planning
- Dry runs and rehearsals

- Identify boundaries
- Define guardrails
- Check with compliance/legal (if required)
- Scenario and Persona
- Define Threat Profile
- Define primary goal (important)
- Define secondary goals
- Engagement approval

Let's take a closer look at Pre-O

Pre-Ops

During Ops

2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

Logistic and Force preparation

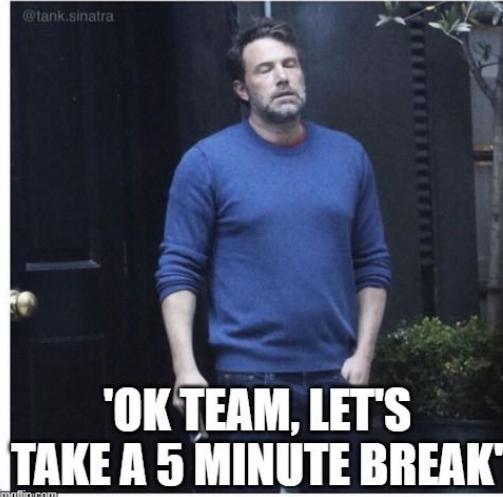
Ops planning

Contingency planning

Dry runs and rehearsals

FIRST DAY ONBOARDING

@tank.sinatra



Onboard primary whitecell

System owners informed

Shortlist secondary whitecell members

Let's take a closer look at P

Pre-Ops

2 ~ 6 months before Ops
Scoping of engagement
Stakeholder onboarding
Pre-Ops meeting
Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

D

ACME Cloud Terrain

aws

Service A

Service B

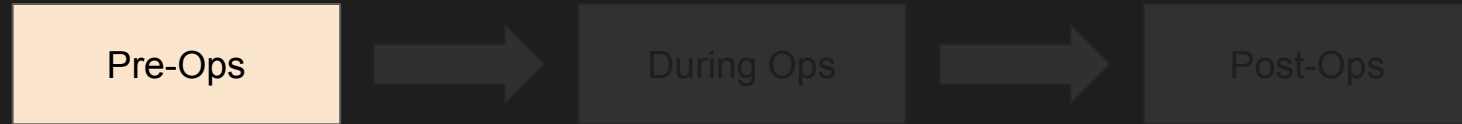
Jenkins

Guard
Duty

IDP Provider X

Finalize Scenario and Persona
Passive reconnaissance
Consolidate passive recon intel
Define the target terrain
Postulate weaknesses
Generate Sub-Task Study

Let's take a closer look at Pre-Ops



2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

Study of sub-tasks

Generate unit tests

Exploitability research

Accept/Reject sub-task

Result presentation

Let's take a closer look at Pre-Ops

Pre-Ops

During Ops

Post-Ops

2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

Adversary infrastructure provisioning

Collector & Redirector provisioning

DNS resource allocation

C2 checks and deployment

Payload testing

Payload delivery testing

Let's take a closer look at Pre-Ops

Pre-Ops

During Ops

Post-Ops

2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

Terrain in General (Attacker/Defender)

Terrain in Detail (Key Terrain)

Wargaming (Attacker/Defender/Mitigation)

Delivery of Approach

Ops Infrastructure confirmation

Attack Plan (phases of attack)

Manpower

Timings

Expected start and end date/time

Terrain in General (Attacker)

Terrain in General (Attacker/Defender)

Terrain in Detail (Key Terrain)

Wargaming (Attacker/Defender/Mitigation)

Delivery of Approach

Ops Infrastructure confirmation

Attack Plan (phases of attack)

Manpower

Timings

Expected start and end date/time

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

Asset	Effects
IDP Provider X	The presence of IDP Provider X suggests that an attacker could <u>leverage on leaked Administrator API keys</u> and move laterally within the organization through the <u>manipulation of LDAP groups or account access</u> .
Jenkins	The presence of Jenkins suggests that an attacker could use this as a <u>foothold to the CI/CD pipeline</u> once access to Jenkins is successful.

Terrain in General (Defender)

Terrain in General (Attacker/Defender)

Terrain in Detail (Key Terrain)

Wargaming (Attacker/Defender/Mitigation)

Delivery of Approach

Ops Infrastructure confirmation

Attack Plan (phases of attack)

Manpower

Timings

Expected start and end date/time

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

Asset	Effects
AWS Guard Duty	The presence of AWS Guard Duty suggests any anomalous AWS events would alert the defender, hence an attacker should be aware of the nature of the payload and if payloads would have a risk of triggering AWS Guard Duty Blackbox ML detection mechanism.
EDR X	The presence of EDR X suggests that risky commands executed in the environment would be flagged, hence an attacker should plan for non-standard command executions to evade detection.

Terrain in Detail (Identified Key Terrain)

Terrain in General (Attacker/Defender)

Terrain in Detail (Key Terrain)

Wargaming (Attacker/Defender/Mitigation)

Delivery of Approach

Ops Infrastructure confirmation

Attack Plan (phases of attack)

Manpower

Timings

Expected start and end date/time

Sub-Task study

Logistic and Force preparation

Ops planning

Contingency planning

Dry runs and rehearsals

- Jenkins being a prime target where majority of Engineers have access to, any misconfigured jobs/workspace would result in a potential Remote Code Execution (RCE) exploit thereby providing the attacker the entry point for Cloud Environment.
- It was observed that Jenkins was primarily used in the early days of the company, and legacy/risky jobs/workspace might still linger in the system.
- Hence, due to its history, the AWS instance role applied to the Jenkins System might have a high privilege profile.

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)

Wargaming

Ops-Planning

No.	Attacker	Defender	Attacker Mitigation on Defender
1	RCE on Jenkins Slave	Detection by EDR X	Use Python to execute encoded Go Binary which executes AWS SDK in memory. Encrypt exfiltrated payloads with external key. ** Short story here **
2	Data Exfiltration	Block/Deny network connection to webhook	Prepare backup DNS/Resources for data collection
3	Privilege Escalation AWS using iamPassRole and ec2RunInstance	Suspend/Terminate/Disconnect suspected instance	Use user-data during run-instance to pass command and executed on runtime. Remove and terminate instance once actions are completed

Delivery of approach

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)

Delivery of Approach

Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

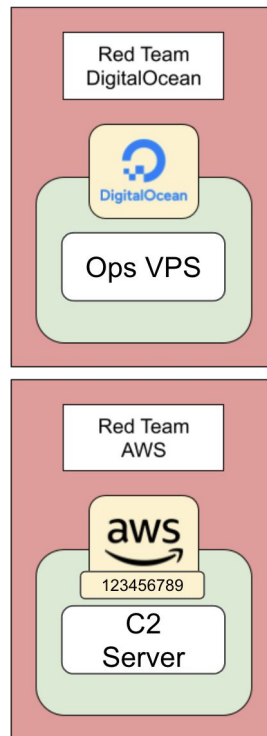
1. “Quick Attack” (Primary approach)
 - a. Focus and stealth and time spent on actions (15mins max)
 - b. Payloads pre-scripted/skeleton code prepared
2. “Air Strike” (Backup approach)
 - a. Trigger waves of alerts to soften defender manpower
 - b. Main attacks carried out during the triggers of alerts
 - c. Does not focus on stealth, but slowing down defender to discover the true intent

Ops-Planning

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

Ops Infra

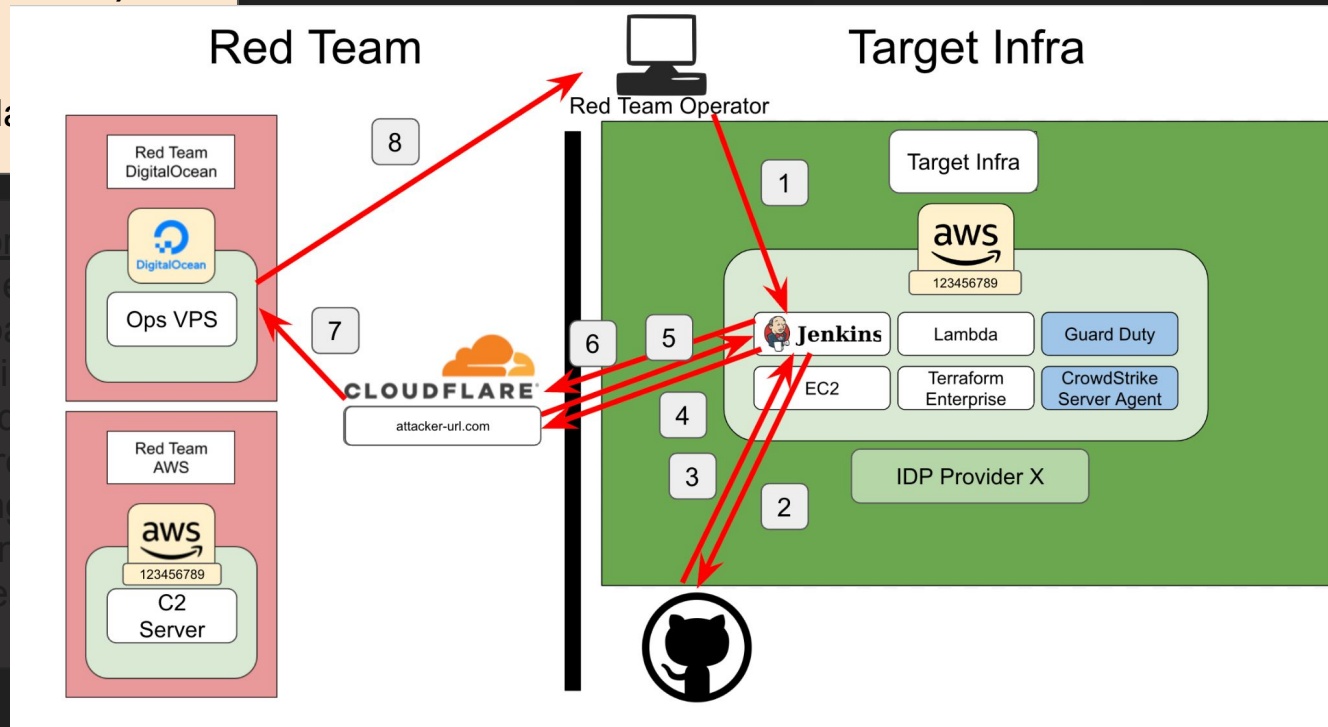


Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)

Manpower
Timings
Expected start and end date

Ops-Planning

Attack Plan



Ops-Planning

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

Manpower

Name	Role
Attacker	
John Doe	Red Team Lead
Jane Doe	Red Team Operator
Defender	
All Blue Team and IR members	Blue Team
White Cell	
John Powell	Head, Cyber Defence
Timothy Bankers	Principal Cyber Security Architect

Ops-Planning

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

Timings

Time (SGT)	Activity
DD/MM/YYYY hhhh(hrs)	Enumeration
DD/MM/YYYY hhhh(hrs)	Staging
DD/MM/YYYY hhhh(hrs)	Launch Stage X
DD/MM/YYYY hhhh(hrs)	Exfiltration of initial artifacts
DD/MM/YYYY hhhh(hrs)	Persistency and Cover
DD/MM/YYYY hhhh(hrs)	Post Exploitation

Ops-Planning

Expected start and end

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

H-Hour
DD/MM/YYYY HHHH(hrs)

End of engagement
Projected end: DD/MM/YYYY HHHH(hrs)
Hard Limit: DD/MM/YYYY HHHH(hrs)

Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

End of Ops Planning

Pre-Ops

2 ~ 6 months before

Scoping of engager

Stakeholder onboard

Pre-Ops meeting

Sub-Task study

Logistic and Force preparation

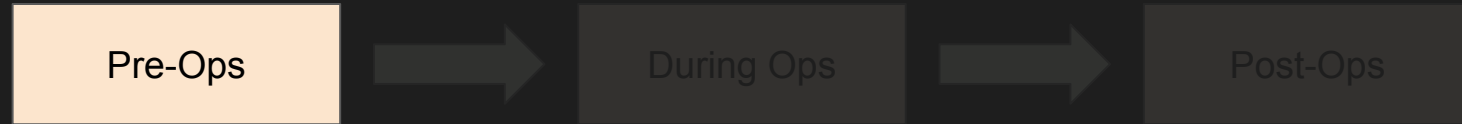
Ops planning

Contingency planning

Dry runs and rehearsals

Terrain in General (Attacker/Defender)
Terrain in Detail (Key Terrain)
Wargaming (Attacker/Defender/Mitigation)
Delivery of Approach
Ops Infrastructure confirmation
Attack Plan (phases of attack)
Manpower
Timings
Expected start and end date/time

Let's take a closer look at Pre-Ops



2 ~ 6 months before Ops
Scoping of engagement
Stakeholder onboarding
Pre-Ops meeting
Sub-Task study
Logistic and Force preparation
Ops planning
Contingency planning
Dry runs and rehearsals

Contingency Ops Plan (similar to Ops Plan)
Spare resource allocation
Backup plan runbook
Scripts to execute contingencies
Indicator(s) to stop engagement

Let's take a closer look

Pre-Ops

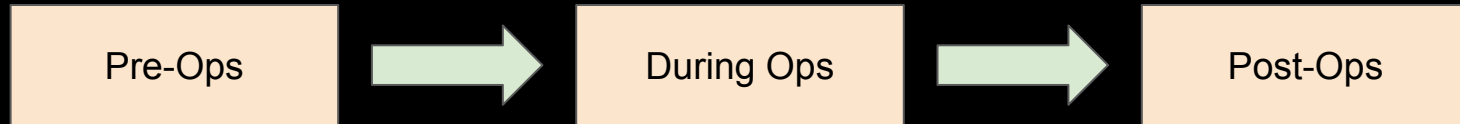
2 ~ 6 months before Ops

- Scoping of engagement
- Stakeholder onboarding
- Pre-Ops meeting
- Sub-Task study
- Logistic and Force preparation
- Ops planning
- Contingency planning
- Dry runs and rehearsals**



- Run end-to-end exploit in sandbox
- Verify payloads are production ready
- Test run C2 with agents
- Record and detail expected behaviors
- 2nd/3rd person verification
- Approval of attack(s)

End of Pre-Ops



2 ~ 6 months before Ops

Scoping of engagement

Stakeholder onboarding

Pre-Ops meeting

Sub-Task study

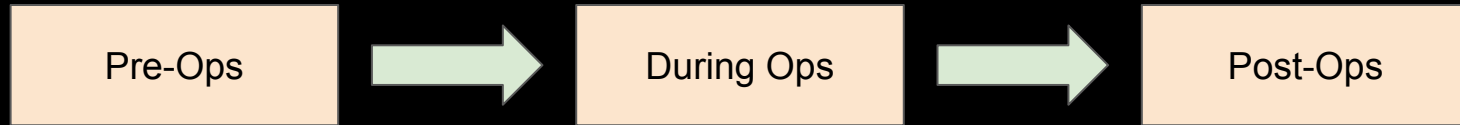
Logistic and Force preparation

Ops planning

Contingency planning

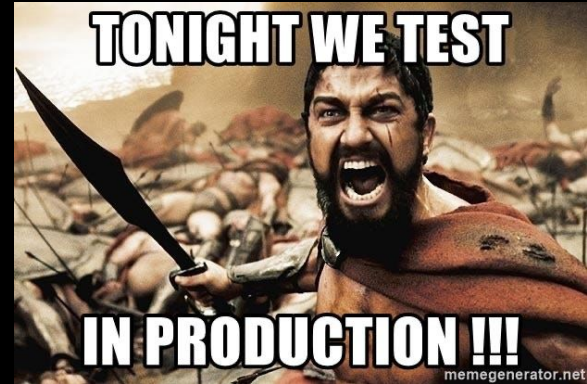
Dry runs and rehearsals

During Ops

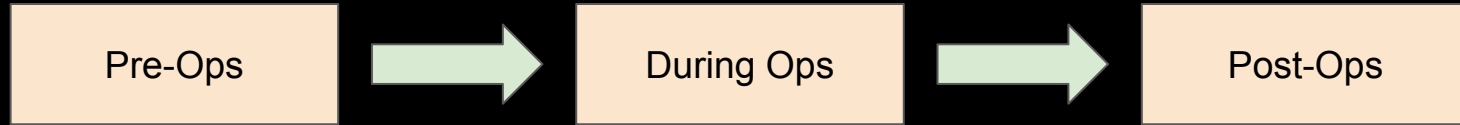


During Ops

Approval of Plan (2 weeks before execution)
C2 management
Infrastructure management
Pipeline management
Strike team coordination
Target monitoring
Backdoor management
Artifact management
Ops logging
Contingency activation



Post Ops



Post Ops

Ops log reconciliation
Report generation
Stakeholder debrief
IR & Detection post mortem
Environment cleanup
Attack process modelling
Reflect and improve



Break Time

Exam Requirements

- Open Book Exam
- Practical + Theory
- 2 Hours
- In Person
- Kali Linux is a MUST
- Use of OpenVPN is required (If you do not know by now, you must approach me. Else, your WILL have difficulty in exam)

Week 13 Presentation Briefing

- Each attacking team will present their findings on the target machine
- Each attacking team will recommend solutions to fix the security issues
- The team who authored the challenges will have the right to comment and address what was not found
- Each attacking team will also have to name the attack path which they enjoyed the most